Informe de seguridad

PharmaBackend · Actividad autónoma · Sesión 10

Estudiante: James Christopher Tequen Oncoy
Curso: Lenguaje de Programación 2
Docente: Benjamin David Reyna Barreto
Fecha de ejecución: 17 de octubre de 2026

C1. Resumen de resultados

Grupo	Casos	Pasan	Fallan
Autenticación	5	5	0
Token	6	6	0
Permisos	5	5	0
Usuarios	3	3	0
CORS	1	1	0
Contraseña, roles y estado	8	8	0
Total	**28**	**28**	**0**

Se ejecutaron **28 casos** mediante 62 peticiones o comprobaciones registradas: los 16 casos base, cuatro propios de grupos distintos y B-01 a B-08. La suite de Maven ejecutó adicionalmente **10 pruebas, sin fallos ni errores** (carga de contexto, JWT y permisos).

Los casos propios son A-05 (credenciales vacías), T-06 (Authorization ausente), P-05 (unión de permisos de supervisor) y U-03 (administración de usuarios por vendedor). Las respuestas distinguen la falta de autenticación del rechazo por permisos.

Entorno y trazabilidad

Oracle 23 en Docker; API principal en localhost:8081; Swagger UI; SPA existente servida en localhost:4200. Para T-03 se inició el mismo JAR en 8082 con otra clave. Esa instancia también emitió el JWT de T-04 con duración de un minuto; se utilizó después de su vencimiento real.

La matriz contiene las peticiones, códigos, mensajes y enlaces a capturas nombradas por caso. El anexo conserva las capturas originales de Swagger, la pestaña Red, consultas Oracle y el registro del cambio de contraseña. Los datos de negocio son nombres y productos normales.

C2. Hallazgos y verificación

No hubo casos funcionales fallidos en la ejecución final. Por ello no corresponde elaborar fichas de fallos con severidad, causa y corrección. Las respuestas de rechazo esperadas forman parte de los casos que pasan.

Resultados de los endpoints construidos

Operación	Reglas comprobadas y resultado
PUT /auth/password	204 al cambiar; 400 por formato o longitud; 409 por contraseña actual incorrecta o nueva idéntica. La cuenta se toma de Authentication.getName(). BCrypt verifica y codifica; la respuesta no contiene contraseña.
PUT /usuarios/{id}/roles	200 al reemplazar roles; 400 por conjunto vacío; 404 por usuario o rol inexistente; 409 si el administrador intenta quitarse ADMIN. Un vendedor recibe 403.
PATCH /usuarios/{id}/estado	200 al desactivar y reactivar; 404 si el usuario no existe; 409 ante autodesactivación del administrador; 403 sin permiso. La cuenta desactivada pierde acceso con su token previo y su login devuelve el mensaje genérico.

Comprobaciones de persistencia y registro

U-02 creó la cuenta de María Huamán con una única relación VENDEDOR. La consulta a usuarios y usuario_roles confirmó un hash BCrypt con prefijo $2a$10$; el DTO no expone password. B-05 dejó exactamente dos relaciones para vendedor: ALMACENERO y VENDEDOR. Las consultas se ejecutaron directamente en Oracle mediante JDBC y se incluyen con sus resultados; son reproducibles en SQL Developer.

B-01 confirmó un registro INFO “Contraseña actualizada: usuario=vendedor”; se verificó que las contraseñas enviadas no aparezcan en el log. Tras las pruebas se restituyeron la contraseña y los roles originales del vendedor; la cuenta maria creada en U-02 permanece registrada.

Límites y estado de la entrega

Las evidencias corresponden al entorno local de clase. C-01 registró el OPTIONS y el GET reales del navegador con respuesta 200 y el origen permitido localhost:4200. La colección exportada deja vacías todas las variables de tokens.

Versionamiento: rama feature/seguridad-pruebas-Tequen, creada desde feature/dev-TEQUEN, la rama de trabajo disponible. No existía la rama de práctica indicada. Los commits llevan su fecha real del 17/10/2026; **queda pendiente el requisito de commits en días distintos**. El repositorio utiliza main en lugar de master. La rama aún no se ha publicado y el PR está pendiente; su base sería main. El criterio completo de versionamiento no se considera cumplido.

C3. Análisis de seguridad

1. Respuesta genérica del login

El mismo mensaje “Usuario o contraseña incorrectos” evita que la respuesta distinga una cuenta inexistente, una contraseña equivocada y una cuenta deshabilitada. Un mensaje diferente permitiría enumerar usuarios válidos o conocer su estado para dirigir intentos contra ellos. GlobalExceptionHandler.handleAuthentication aplica la respuesta común a AuthenticationException; A-02 y A-03 comprobaron la igualdad del mensaje. Esto reduce la información expuesta por el texto; no demuestra igualdad de tiempos de respuesta.

2. Token anterior después del cambio de contraseña

El JWT conserva una firma y una fecha de expiración válidas: AuthServiceImpl.cambiarPassword modifica el hash BCrypt, pero no revoca los tokens emitidos. JwtAuthenticationFilter.doFilterInternal comprueba firma y expiración, luego consulta usuario, estado y permisos; no compara la contraseña ni una versión de credencial. B-01 confirmó que el token anterior sigue funcionando. Una solución es guardar tokenVersion en usuarios e incluirla en el JWT: al cambiar la contraseña se incrementa la versión y el filtro rechaza tokens con una versión anterior.

3. Publicación accidental del secreto

Quien obtiene la clave HMAC puede firmar un JWT que suplante el sub de un usuario existente, incluso admin. Aunque el filtro recarga los permisos desde la base y no confía en las authorities del payload para autorizar, suplantar un administrador sigue siendo crítico. Se debe rotar inmediatamente la clave, retirar la anterior de todas las instancias, revisar accesos, reemplazar credenciales comprometidas y retirar el secreto del repositorio y su historial. JwtService recibe la clave desde JWT_SECRET; T-03 confirmó que otra clave rechaza el token anterior.

4. Protección de reportes con @PreAuthorize

La anotación del ReporteController liga el permiso REPORTES_VER al controlador y sus métodos, de modo que cambiar una URL no elimina esa protección si la anotación permanece. SecurityConfig mantiene además la autenticación general. P-03 comprobó el rechazo para vendedor y almacén. La desventaja es que las reglas quedan distribuidas entre la configuración y las anotaciones, lo que dificulta revisar toda la política. También depende de @EnableMethodSecurity y de que la invocación pase por el proxy de Spring; una llamada interna puede no ser interceptada.

Referencias al código verificado

Paquete pe.edu.upeu.PharmaBackend: controller/AuthController y ReporteController; service/impl/AuthServiceImpl y UsuarioServiceImpl; security/JwtAuthenticationFilter, JwtService, UsuarioDetailsService y PermisosPorRol; config/SecurityConfig; exception/GlobalExceptionHandler. Los casos correspondientes y los resultados completos se encuentran en la matriz y en el anexo.